Table 6.5 Strengths and limitations of attribute-based authorization (ABAC)

Strengths	Limitations
Enables fine-grained access control based on rich context	Policies can become complex and difficult to manage over time
Supports real-time decisions using current attributes and signals	Requires consistent and accurate attribute data from multiple systems
Decouples policy logic from application code, improving maintainability	Understanding access decisions can be difficult due to distributed inputs
Scales well across diverse teams, systems, and resource types	Limited visibility into which policies affect which resources without tooling
Flexible enough to model conditional access and regulatory requirements	Performance may suffer if attribute retrieval or policy evaluation is not optimized
Improves auditability and consistency through centralized policy evaluation	Usually requires custom tooling for policy management, simulation, and reporting

Ultimately, ABAC shines when organizations need to implement nuanced, context-aware controls across a wide range of systems and scenarios. It offers a framework for expressing intent through policies and dynamically enforcing that intent at runtime. However, to realize these benefits, organizations must invest in attribute quality, governance, and tools that support the entire lifecycle of policy creation, evaluation, and auditing.

6.2.4 Where ABAC makes sense

As we've discussed, ABAC excels in environments where access decisions depend on dynamic factors and fine-grained conditions. In contrast to models that rely on static assignments or predefined relationships, ABAC shines when access needs vary based on time, location, device state, or other runtime signals. This makes it especially useful for enterprise systems that serve diverse functions across departments, where policies must reflect detailed regulatory or operational requirements without constant manual updates.

At ACME Corp, the identity team adopted ABAC to manage internal access in a scalable and layered manner. A company-wide policy enforced a baseline requirement: all access to sensitive systems must come from company-managed devices. Additionally, engineering layered on additional policies for deploying code—engineers with high clearance could deploy during business hours from managed devices, but outside business hours,